

**Scheduled Maintenance on US Academy VPNs 16/5/2024**

All US Academy VPNs will be unavailable 09:00-12:00 UTC. Please utilize EU VPNs during this time.

John The Ripper

[John the Ripper](#) ([JTR](#) or [john](#)) is an essential pentesting tool used to check the strength of passwords and crack encrypted (or hashed) passwords using either brute force or dictionary attacks. It is open-source software initially developed for UNIX-based systems and first released in 1996. It has become a staple of security professionals due to its various capabilities. The "Jumbo" variant is recommended for those in the security field, as it has performance optimizations and additional features such as multilingual word lists and support for 64-bit architectures. This version is more effective in cracking passwords with greater accuracy and speed.

With this, we can use various tools to convert different types of files and hashes into a format that is usable by John. Additionally, the software is regularly updated to keep up with the current security trends and technologies, ensuring user security.

Encryption Technologies

Encryption Technology	Description
UNIX crypt(3)	Crypt(3) is a traditional UNIX encryption system with a 56-bit key.
Traditional DES-based	DES-based encryption uses the Data Encryption Standard algorithm to encrypt data.
bigcrypt	Bigcrypt is an extension of traditional DES-based encryption. It uses a 128-bit key.
BSDI extended DES-based	BSDI extended DES-based encryption is an extension of the traditional DES-based encryption and uses a 168-bit key.
FreeBSD MD5-based (Linux & Cisco)	FreeBSD MD5-based encryption uses the MD5 algorithm to encrypt data with a 128-bit key.
OpenBSD Blowfish-based	OpenBSD Blowfish-based encryption uses the Blowfish algorithm to encrypt data with a 448-bit key.
Kerberos/AFS	Kerberos and AFS are authentication systems that use encryption to ensure secure entity communication.
Windows LM	Windows LM encryption uses the Data Encryption Standard algorithm to encrypt data with a 56-bit key.
DES-based tripcodes	DES-based tripcodes are used to authenticate users based on the Data Encryption Standard algorithm.
SHA-crypt hashes	SHA-crypt hashes are used to encrypt data with a 256-bit key and are available in newer versions of Fedora and Ubuntu.
SHA-crypt and SUNMD5 hashes (Solaris)	SHA-crypt and SUNMD5 hashes use the SHA-crypt and MD5 algorithms to encrypt data with a 256-bit key and are available in Solaris.
...	and many more.

Attack Methods

Dictionary Attacks

Dictionary attacks involve using a pre-generated list of words and phrases (known as a dictionary) to attempt to crack a password. This list of words and phrases is often acquired from various sources, such as publicly available dictionaries, leaked passwords, or even purchased from specialized companies. The dictionary is then used to generate a series of strings which are then used to

**Scheduled Maintenance on US Academy VPNs 16/5/2024**

All US Academy VPNs will be unavailable 09:00-12:00 UTC. Please utilize EU VPNs during this time.

authentication.

Brute Force Attacks

Brute force attacks involve attempting every conceivable combination of characters that could form a password. This is an extremely slow process, and using this method is typically only advisable if there are no other alternatives. It is also important to note that the longer and more complex the password, the more difficult it is to crack and the longer it will take to exhaust every combination. For this reason, it is highly recommended that passwords be at least 8 characters in length, with a combination of letters, numbers, and symbols.

Rainbow Table Attacks

Rainbow table attacks involve using a pre-computed table of hashes and their corresponding plaintext passwords, which is a much faster method than a brute-force attack. However, this method is limited by the rainbow table size – the larger the table, the more passwords, and hashes it can store. Additionally, due to the nature of the attack, it is impossible to use rainbow tables to determine the plaintext of hashes not already included in the table. As a result, rainbow table attacks are only effective against hashes already present in the table, making the larger the table, the more successful the attack.

Cracking Modes

Single Crack Mode is one of the most common John modes used when attempting to crack passwords using a single password list. It is a brute-force attack, meaning all passwords on the list are tried, one by one, until the correct one is found. This method is the most basic and straightforward way of cracking passwords and is thus a popular choice for those wishing to gain access to a secure system. It is, however, far from the most efficient method since it can take an indefinite amount of time to crack a password, depending on the length and complexity of the password in question. The basic syntax for the command is:

Single Crack Mode

John The Ripper

```
dbcypth0n@htb[/htb]$ john --format=<hash_type> <hash or hash_file>
```

For example, if we have a file named **hashes_to_crack.txt** that contains **SHA-256** hashes, the command to crack them would be:

John The Ripper

```
dbcypth0n@htb[/htb]$ john --format=sha256 hashes_to_crack.txt
```

- **john** is the command to run the John the Ripper program
- **--format=sha256** specifies that the hash format is SHA-256
- **hashes.txt** is the file name containing the hashes to be cracked

When we run the command, John will read the hashes from the specified file, and then it will try to crack them by comparing them to the words in its built-in wordlist and any additional wordlists specified with the **--wordlist** option. Additionally, it will use any rules set with the **--rules** option (if any rules are given) to generate further candidate passwords.

The process of cracking the passwords can be **very time-consuming**, as the amount of time required to crack a password depends on multiple factors, such as the complexity of the password, machine configuration, and the size of the wordlist. Cracking passwords

**Scheduled Maintenance on US Academy VPNs 16/5/2024**

All US Academy VPNs will be unavailable 09:00-12:00 UTC. Please utilize EU VPNs during this time.

John will output the cracked passwords to the console and the file `john.pot` (`~/ .john/john.pot`) to the current user's home directory. Furthermore, it will continue cracking the remaining hashes in the background, and we can check the progress by running the `john --show` command. To maximize the chances of success, it is important to ensure that the wordlists and rules used are comprehensive and up to date.

Cracking with John

Hash Format	Example Command	Description
afs	<code>john --format=afs hashes_to_crack.txt</code>	AFS (Andrew File System) password hashes
bfegg	<code>john --format=bfegg hashes_to_crack.txt</code>	bfegg hashes used in Eggdrop IRC bots
bf	<code>john --format=bf hashes_to_crack.txt</code>	Blowfish-based crypt(3) hashes
bsdi	<code>john --format=bsdi hashes_to_crack.txt</code>	BSDi crypt(3) hashes
crypt(3)	<code>john --format=crypt hashes_to_crack.txt</code>	Traditional Unix crypt(3) hashes
des	<code>john --format=des hashes_to_crack.txt</code>	Traditional DES-based crypt(3) hashes
dmd5	<code>john --format=dmd5 hashes_to_crack.txt</code>	DMD5 (Dragonfly BSD MD5) password hashes
dominosec	<code>john --format=dominosec hashes_to_crack.txt</code>	IBM Lotus Domino 6/7 password hashes
EPiServer SID hashes	<code>john --format=episerver hashes_to_crack.txt</code>	EPiServer SID (Security Identifier) password hashes
hdaa	<code>john --format=hdaa hashes_to_crack.txt</code>	hdaa password hashes used in Openwall GNU/Linux
hmac-md5	<code>john --format=hmac-md5 hashes_to_crack.txt</code>	hmac-md5 password hashes
hmailserver	<code>john --format=hmailserver hashes_to_crack.txt</code>	hmailserver password hashes
ipb2	<code>john --format=ipb2 hashes_to_crack.txt</code>	Invision Power Board 2 password hashes
krb4	<code>john --format=krb4 hashes_to_crack.txt</code>	Kerberos 4 password hashes
krb5	<code>john --format=krb5 hashes_to_crack.txt</code>	Kerberos 5 password hashes
LM	<code>john --format=LM hashes_to_crack.txt</code>	LM (Lan Manager) password hashes
lotus5	<code>john --format=lotus5 hashes_to_crack.txt</code>	Lotus Notes/Domino 5 password hashes
mscash	<code>john --format=mscash hashes_to_crack.txt</code>	MS Cache password hashes
mscash2	<code>john --format=mscash2 hashes_to_crack.txt</code>	MS Cache v2 password hashes
mschapv2	<code>john --format=mschapv2 hashes_to_crack.txt</code>	MS CHAP v2 password hashes
mskrb5	<code>john --format=mskrb5 hashes_to_crack.txt</code>	MS Kerberos 5 password hashes
mssql05	<code>john --format=mssql05 hashes_to_crack.txt</code>	MS SQL 2005 password hashes
mssql	<code>john --format=mssql hashes_to_crack.txt</code>	MS SQL password hashes
mysql-fast	<code>john --format=mysql-fast hashes_to_crack.txt</code>	MySQL fast password hashes
mysql	<code>john --format=mysql hashes_to_crack.txt</code>	MySQL password hashes

**Scheduled Maintenance on US Academy VPNs 16/5/2024**

All US Academy VPNs will be unavailable 09:00-12:00 UTC. Please utilize EU VPNs during this time.

NETLMv2	<code>john --format=netlmv2 hashes_to_crack.txt</code>	NETLMv2 (NT LAN Manager version 2) password hashes
NETNTLM	<code>john --format=netntlm hashes_to_crack.txt</code>	NETNTLM (NT LAN Manager) password hashes
NETNTLMv2	<code>john --format=netntlmv2 hashes_to_crack.txt</code>	NETNTLMv2 (NT LAN Manager version 2) password hashes
NEThalflm	<code>john --format=nethalflm hashes_to_crack.txt</code>	NEThalflm (NT LAN Manager) password hashes
md5ns	<code>john --format=md5ns hashes_to_crack.txt</code>	md5ns (MD5 namespace) password hashes
nsldap	<code>john --format=nsldap hashes_to_crack.txt</code>	nsldap (OpenLDAP SHA) password hashes
ssha	<code>john --format=ssha hashes_to_crack.txt</code>	ssha (Salted SHA) password hashes
NT	<code>john --format=nt hashes_to_crack.txt</code>	NT (Windows NT) password hashes
openssha	<code>john --format=openssha hashes_to_crack.txt</code>	OPENSsh private key password hashes
oracle11	<code>john --format=oracle11 hashes_to_crack.txt</code>	Oracle 11 password hashes
oracle	<code>john --format=oracle hashes_to_crack.txt</code>	Oracle password hashes
pdf	<code>john --format=pdf hashes_to_crack.txt</code>	PDF (Portable Document Format) password hashes
phpass-md5	<code>john --format=phpass-md5 hashes_to_crack.txt</code>	PHPass-MD5 (Portable PHP password hashing framework) password hashes
phps	<code>john --format=phps hashes_to_crack.txt</code>	PHPS password hashes
pix-md5	<code>john --format=pix-md5 hashes_to_crack.txt</code>	Cisco PIX MD5 password hashes
po	<code>john --format=po hashes_to_crack.txt</code>	Po (Sybase SQL Anywhere) password hashes
rar	<code>john --format=rar hashes_to_crack.txt</code>	RAR (WinRAR) password hashes
raw-md4	<code>john --format=raw-md4 hashes_to_crack.txt</code>	Raw MD4 password hashes
raw-md5	<code>john --format=raw-md5 hashes_to_crack.txt</code>	Raw MD5 password hashes
raw-md5-unicode	<code>john --format=raw-md5-unicode hashes_to_crack.txt</code>	Raw MD5 Unicode password hashes
raw-sha1	<code>john --format=raw-sha1 hashes_to_crack.txt</code>	Raw SHA1 password hashes
raw-sha224	<code>john --format=raw-sha224 hashes_to_crack.txt</code>	Raw SHA224 password hashes
raw-sha256	<code>john --format=raw-sha256 hashes_to_crack.txt</code>	Raw SHA256 password hashes
raw-sha384	<code>john --format=raw-sha384 hashes_to_crack.txt</code>	Raw SHA384 password hashes
raw-sha512	<code>john --format=raw-sha512 hashes_to_crack.txt</code>	Raw SHA512 password hashes
salted-sha	<code>john --format=salted-sha hashes_to_crack.txt</code>	Salted SHA password hashes
sapb	<code>john --format=sapb hashes_to_crack.txt</code>	SAP CODVN B (BCODE) password hashes
sapg	<code>john --format=sapg hashes_to_crack.txt</code>	SAP CODVN G (PASSCODE) password hashes
sha1-gen	<code>john --format=sha1-gen hashes_to_crack.txt</code>	Generic SHA1 password hashes
skey	<code>john --format=skey hashes_to_crack.txt</code>	S/Kev (One-time password) hashes

**Scheduled Maintenance on US Academy VPNs 16/5/2024**

All US Academy VPNs will be unavailable 09:00-12:00 UTC. Please utilize EU VPNs during this time.

xsha	<code>john --format=xsha hashes_to_crack.txt</code>	xsha (Extended SHA) password hashes
zip	<code>john --format=zip hashes_to_crack.txt</code>	ZIP (WinZip) password hashes

Wordlist Mode

Wordlist Mode is used to crack passwords using multiple lists of words. It is a dictionary attack which means it will try all the words in the lists one by one until it finds the right one. It is generally used for cracking multiple password hashes using a wordlist or a combination of wordlists. It is more effective than Single Crack Mode because it utilizes more words but is still relatively basic. The basic syntax for the command is:

John The Ripper

```
dbcypn@htb[/htb]$ john --wordlist=<wordlist_file> --rules <hash_file>
```

First, we specify the wordlist file or files to use for cracking the password hashes. The wordlist(s) can be in plain text format, with one word per line. Multiple wordlists can be specified by separating them with a comma. Then we can specify a rule set or apply the built-in mangling rules to the words in the wordlist. These rules generate candidate passwords using transformations such as appending numbers, capitalizing letters and adding special characters.

Incremental Mode

Incremental Mode is an advanced John mode used to crack passwords using a character set. It is a hybrid attack, which means it will attempt to match the password by trying all possible combinations of characters from the character set. This mode is the most effective yet most time-consuming of all the John modes. This mode works best when we know what the password might be, as it will try all the possible combinations in sequence, starting from the shortest one. This makes it much faster than the brute force attack, where all combinations are tried randomly. Moreover, the incremental mode can also be used to crack weak passwords, which may be challenging to crack using the standard John modes. The main difference between incremental mode and wordlist mode is the source of the password guesses. Incremental mode generates the guesses on the fly, while wordlist mode uses a predefined list of words. At the same time, the single crack mode is used to check a single password against a hash.

The syntax for running John the Ripper in incremental mode is as follows:

Incremental Mode in John

John The Ripper

```
dbcypn@htb[/htb]$ john --incremental <hash_file>
```

Using this command we will read the hashes in the specified hash file and then generate all possible combinations of characters, starting with a single character and incrementing with each iteration. It is important to note that this mode is **highly resource intensive** and can take a long time to complete, depending on the complexity of the passwords, machine configuration, and the number of characters set. Additionally, it is important to note that the default character set is limited to **a-zA-Z0-9**. Therefore, if we attempt to crack complex passwords with special characters, we need to use a custom character set.

Cracking Files

**Scheduled Maintenance on US Academy VPNs 16/5/2024**

All US Academy VPNs will be unavailable 09:00-12:00 UTC. Please utilize EU VPNs during this time.

Cracking Files with John

John The Ripper

```
cry0l1t3@htb:~$ <tool> <file_to_crack> > file.hash
cry0l1t3@htb:~$ pdf2john server_doc.pdf > server_doc.hash
cry0l1t3@htb:~$ john server_doc.hash
# OR
cry0l1t3@htb:~$ john --wordlist=<wordlist.txt> server_doc.hash
```

Additionally, we can use different modes for this with our personal wordlists and rules. We have created a list that includes many but not all tools that can be used for John:

Tool	Description
pdf2john	Converts PDF documents for John
ssh2john	Converts SSH private keys for John
mscash2john	Converts MS Cash hashes for John
keychain2john	Converts OS X keychain files for John
rar2john	Converts RAR archives for John
pfx2john	Converts PKCS#12 files for John
truecrypt_volume2john	Converts TrueCrypt volumes for John
keepass2john	Converts KeePass databases for John
vncpcap2john	Converts VNC PCAP files for John
putty2john	Converts PuTTY private keys for John
zip2john	Converts ZIP archives for John
hccap2john	Converts WPA/WPA2 handshake captures for John
office2john	Converts MS Office documents for John
wpa2john	Converts WPA/WPA2 handshakes for John

More of these tools can be found on [Pwnbox](#) in the following way:

John The Ripper

```
dbcypth0n@htb[/htb]$ locate *2john*

/usr/bin/bitlocker2john
/usr/bin/dmg2john
/usr/bin/gpg2john
/usr/bin/hccap2john
/usr/bin/keepass2john
/usr/bin/putty2john
/usr/bin/racf2john
/usr/bin/rar2john
/usr/bin/uaf2john
```

**Scheduled Maintenance on US Academy VPNs 16/5/2024**

All US Academy VPNs will be unavailable 09:00-12:00 UTC. Please utilize EU VPNs during this time.

```
/usr/share/john/2password2john.pl  
/usr/share/john/7z2john.pl  
/usr/share/john/DPAPImk2john.py  
/usr/share/john/adxcsovf2john.py  
/usr/share/john/aem2john.py  
/usr/share/john/aix2john.pl  
/usr/share/john/aix2john.py  
/usr/share/john/andotp2john.py  
/usr/share/john/androidbackup2john.py  
...SNIP...
```

In this module, we will work a lot with John and should therefore know what this tool is capable of.

[< Previous](#)[Next >](#)**+10 Streak pts**[✔ Mark Complete & Next](#)[📄 Cheat Sheet](#)[📖 Resources](#)**Table of Contents****Introduction**[Theory of Protection](#)[Credential Storage](#)[John The Ripper](#)**Remote Password Attacks**[📦 Network Services](#)[📦 Password Mutations](#)[📦 Password Reuse / Default Passwords](#)**Windows Local Password Attacks**[📦 Attacking SAM](#)[📦 Attacking LSASS](#)[📦 Attacking Active Directory & NTDS.dit](#)[📦 Credential Hunting in Windows](#)**Linux Local Password Attacks**[📦 Credential Hunting in Linux](#)[📦 Passwd, Shadow & Opasswd](#)**Windows Lateral Movement**[📦 Pass the Hash \(PtH\)](#)[📦 Pass the Ticket \(PtT\) from Windows](#)[📦 Pass the Ticket \(PtT\) from Linux](#)**Cracking Files**

**Scheduled Maintenance on US Academy VPNs 16/5/2024**

All US Academy VPNs will be unavailable 09:00-12:00 UTC. Please utilize EU VPNs during this time.

Password Management

Password Policies

Password Managers

Skills Assessment

 Password Attacks Lab - Easy

 Password Attacks Lab - Medium

 Password Attacks Lab - Hard

My Workstation

O F F L I N E

 Start Instance

 / 1 spawns left